

Lección 02: Proceso de investigación forense

Proveer los fundamentos para ordenar, justificar y auditar un proceso forense de manera autónoma.



Investigar sin alterar información, exceder el permiso ni concluir antes de analizar.

El riesgo de actuar sin método

Intervenir sin un proceso estructurado puede transformar una sospecha en **conclusión prematura**, alterar evidencia **irreversiblemente**, exceder **permisos legales** o perder el **contexto** crítico de los datos.

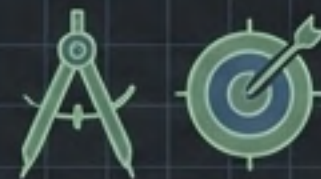


Cualidades de un proceso forense válido

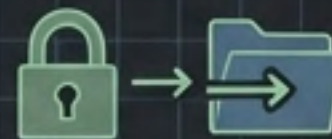
Un trabajo profesional se distingue porque cada decisión es:



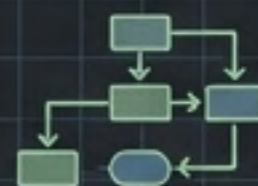
Autorizada: Tiene fundamento legal/administrativo y un responsable claro.



Pertinente: Responde directamente a las preguntas de la investigación.



Controlada: Protege las fuentes originales y registra todo cambio.



Trazable: Permite reconstruir paso a paso el tratamiento de la evidencia.

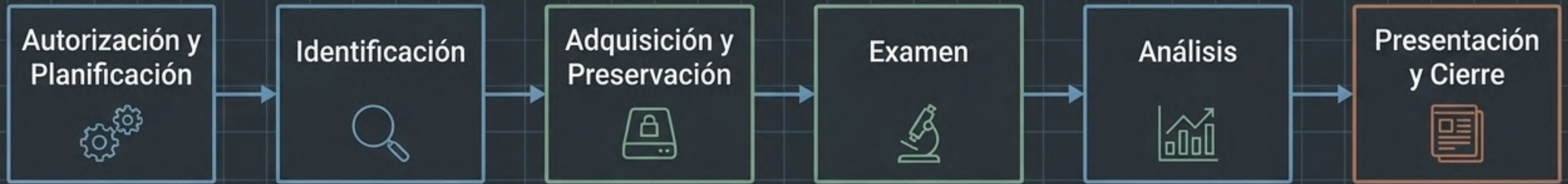


Revisable: Un tercero puede auditar y comprobar la metodología.



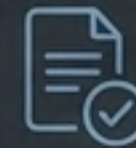
Comunicable: El resultado declara claramente sus propios límites.

Flujo del proceso forense



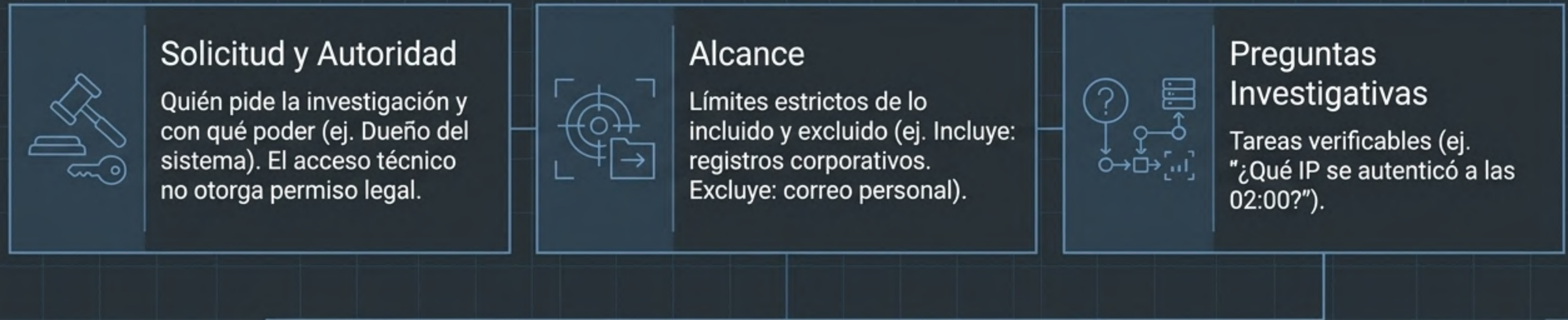
La documentación (Bitácora y Custodia) acompaña y sustenta todas las fases.

Relación con NIST SP 800-86

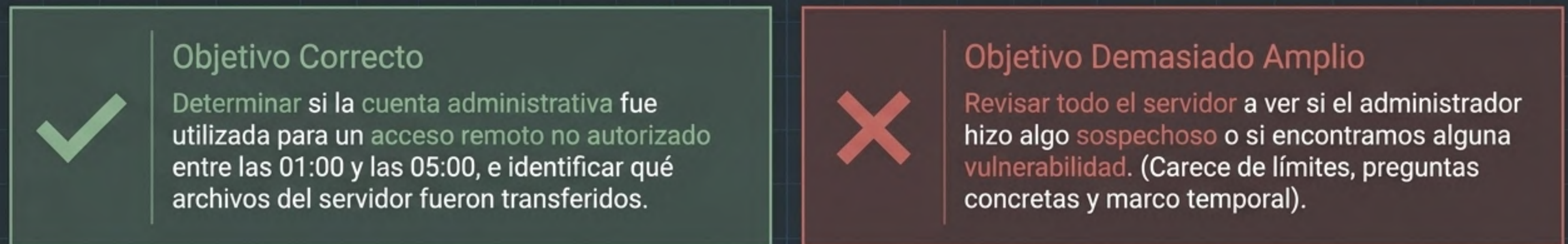


El marco NIST agrupa el trabajo en: Recolección, Examen, Análisis y Reporte. Nuestro mapa detalla este flujo: la Autorización, Planificación, Identificación, Adquisición y Preservación conforman el tratamiento inicial que garantiza una Recolección segura, metódica y pertinente.

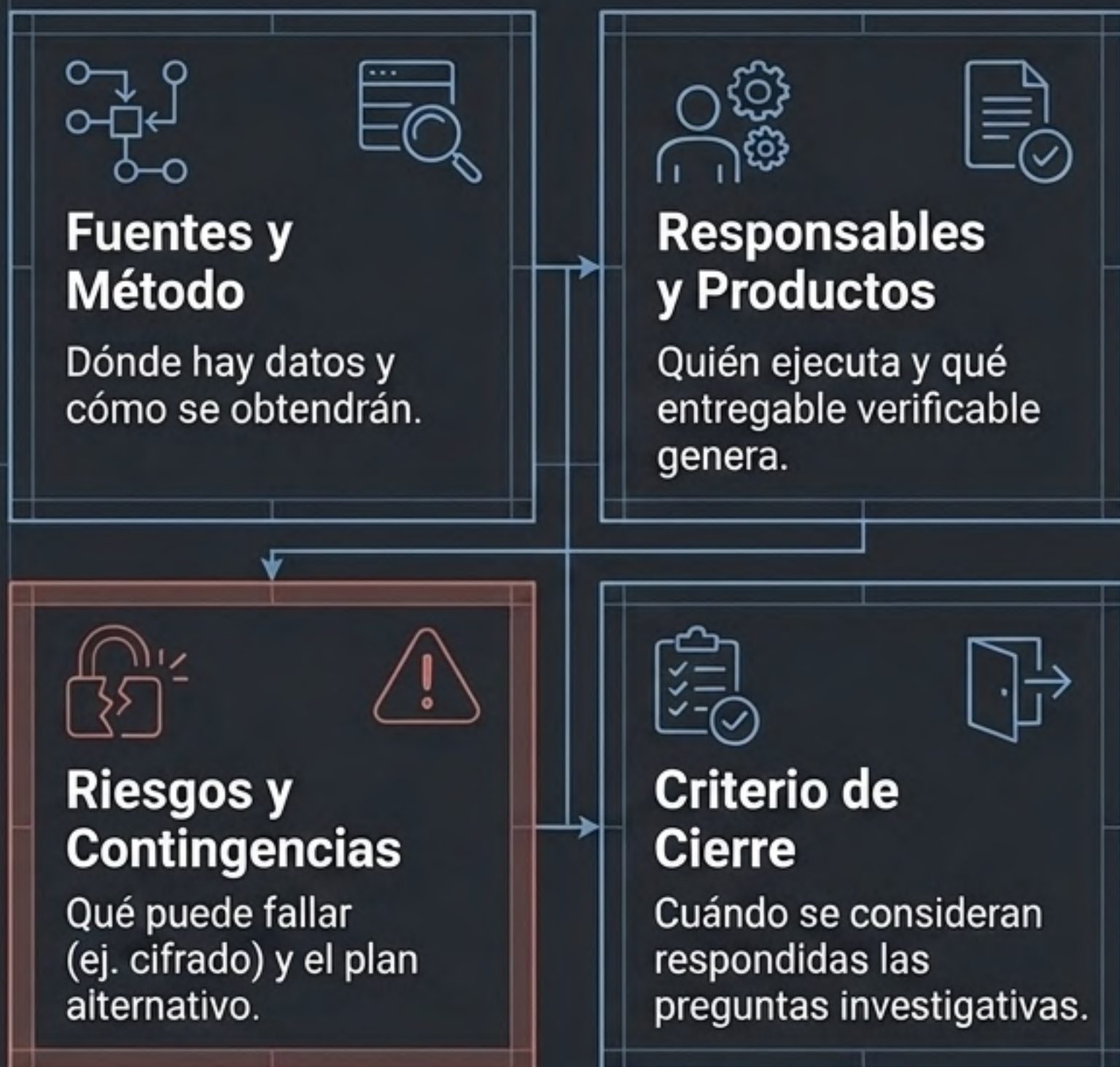
Las bases antes de intervenir



Comparación de Objetivos (Caso: Acceso remoto fuera de horario)

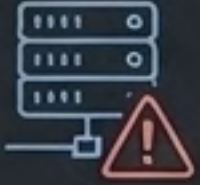


Planificar antes de ejecutar



¿Cómo determinar la Prioridad de las fuentes?

No se recolecta al azar. La prioridad va más allá de la volatilidad (pérdida al apagar). Depende de:

-  **Relevancia:**
Valor esperado para resolver el caso.
-  **Volatilidad y Rotación:**
Riesgo de pérdida por sobreescritura (ej. RAM o logs cíclicos).
-  **Impacto:**
Consecuencia operativa de intervenir la fuente.
-  **Copias, autorización y capacidad:**
¿Existe otra copia disponible? ¿Está permitido y es técnicamente viable obtenerla ahora?

Localizar y caracterizar no es recolectar todo

Identificar es mapear fuentes plausibles antes de tocarlas. Implica evaluar si la fuente existía en el período investigado, su zona horaria y quién la controla.

Ejemplo de Inventario Simple (Caso: Acceso remoto)

	Identificador	Propietario	Período de interés	Valor esperado	Volatilidad	Acceso	Zona Horaria	Riesgo
1	SRC-VPN-01	Redes	10-08, 01:00-05:00	IP, cuenta, inicio, fin	Alta (rotación 7 días)	Exportación autorizada	UTC-4	⚠ Pérdida por rotación
2	SRC-SRV-02	TI	10-08, 01:00-05:00	Logs del servidor	Media	Acceso directo	UTC	⚠ Desfase horario

Tratamiento de la evidencia original



Identificar: Localizar y caracterizar la fuente de información.



Adquirir: Obtener los datos mediante un método técnico controlado, justificado y autorizado.



Preservar: Mantener la utilidad, contexto e integridad de los datos durante todo el caso.

Principios de preservación

1. **Protección del original:** Siempre que sea posible, el examen se realiza sobre una copia de trabajo verificada. Cualquier intervención directa debe justificarse, autorizarse y documentarse.
2. **Copias de trabajo:** Utilizar copias verificadas y separadas del original.
3. **Metadatos:** Conservar rigurosamente formatos, fechas de creación/modificación y zonas horarias.
4. **Acceso limitado:** Registrar cada transferencia y blindar contra modificaciones accidentales.

Auditoría de las fases iniciales

Fase	Objetivo	Entrada	Acción	Responsable	Producto Verificable	Riesgo de Ejecución
Alcance y Planificación	Definir límites, prioridades y roles.	Solicitud inicial.	Confirmar preguntas, horario, fuentes y exclusiones.	Analista / Supervisor	Plan autorizado.	Exceder el permiso; acceder a datos no pertinentes.
Identificación	Localizar fuentes plausibles.	Plan autorizado y mapa de red/sistemas.	Caracterizar equipos y registros disponibles.	Analista	Inventario priorizado.	Omitir una fuente crítica o perder un log por rotación.
Adquisición / Preservación	Obtener y proteger datos íntegros.	Inventario priorizado.	Realizar obtención controlada y crear copias de trabajo.	Adquisidor / Custodio	Adquisiciones verificables e intactas.	Alterar el original o recolectar sin método seguro.

Dos propósitos distintos: Examen frente a Análisis

Examen (Localización y organización)

Localiza, extrae, filtra y organiza. Produce datos tabulados y recupera artefactos técnicos.

Ejemplo A:

Extrae 5 eventos de autenticación exitosa a las 02:00 a.m.

Ejemplo B:

Organiza los eventos VPN ya adquiridos y enumera los procesos registrados en la copia de trabajo.

Ejemplo C:

Recupera un archivo eliminado del disco.

Análisis (Interpretación)

Correlaciona resultados, interpreta secuencias, responde preguntas y contrasta hipótesis.

Ejemplo A:

Evalúa si esos eventos forman parte de una sesión remota maliciosa coordinada.

Ejemplo B:

Relaciona el usuario VPN con el proceso sospechoso y el horario.

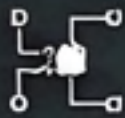
Ejemplo C:

Evalúa cómo ese archivo se relaciona con la posible extracción de datos corporativos.

Diferenciando hechos de inferencias

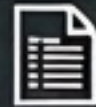
Dato:

valor observado
todavía sin interpretar,
por ejemplo,
192.168.1.5.



Artefacto:

elemento digital
generado o
almacenado por un
sistema o aplicación
que aporta contexto,
por ejemplo, un evento
de inicio de sesión
asociado a esa IP.



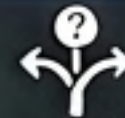
Hallazgo:

Afirmación técnica
respaldada por
evidencia
verificable.



Hipótesis:

Explicación posible
que debe
contrastarse con
datos favorables y
contradictorios.



Conclusión:

Respuesta
razonada
que integra
hallazgos y declara
limitaciones.



⚠ Límites de atribución (Precaución Crítica)

Una coincidencia temporal, una IP o una cuenta registrada no demuestran por sí solas causalidad ni identidad, ni permiten atribuir la acción a una persona. Que la cuenta "Admin" se haya utilizado no prueba que su titular ejecutara el comando. Se requieren fuentes concordantes para aumentar el nivel de confianza, contrastar explicaciones alternativas y declarar las limitaciones.

Controles de documentación que acompañan todo el proceso

Hash (Integridad)

Qué demuestra:
Comparación matemática del contenido exacto de una versión concreta.

Qué NO reemplaza:
No prueba procedencia legal, ni autorización, ni custodia.

Cadena de Custodia (Posesión)

Qué demuestra:
Posesión, control, ubicación física/lógica y transferencias.

Qué NO reemplaza:
No documenta los comandos o procesos técnicos aplicados.

Bitácora Técnica (Acción)

Qué demuestra:
Quién hizo qué, cuándo, cómo, por qué, y el resultado técnico.

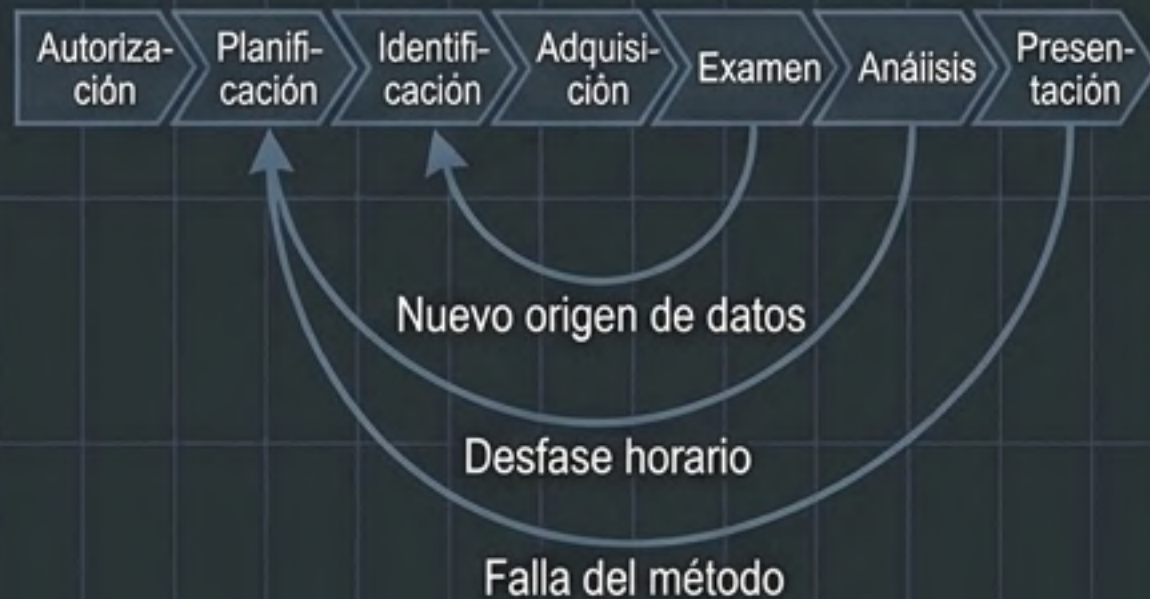
Qué NO reemplaza:
No sirve como registro oficial de traspaso de custodia.

Campos mínimos de la Bitácora: Fecha/hora/zona | Responsable | Copia utilizada | Acción y propósito | Herramienta y versión | Resultado | Errores o desviaciones.

Auditoría de las fases finales

Fase	Objetivo	Entrada	Acción	Responsable	Producto Verificable	Riesgo de Ejecución
Examen	Filtrar y organizar datos relevantes.	Copias de trabajo autorizadas.	Localizar, extraer y organizar artefactos técnicos.	Analista	Tablas, cronologías y artefactos extraídos.	Confundir extracción con interpretación final.
Análisis	Responder preguntas mediante correlación.	Resultados del examen.	Contrastar hipótesis, correlacionar fuentes y evaluar límites.	Analista	Hallazgos, limitaciones y respuestas razonadas.	Sesgo de confirmación; omitir evidencia contradictoria.
Presentación / Cierre	Comunicar respuestas y disponer de evidencia.	Hallazgos y conclusiones.	Redactar comunicación (objetivo, métodos, límites, datos faltantes).	Analista	Informe proporcional y archivo ordenado.	Afirmar conclusiones definitivas ocultando fuentes ausentes.

Cuándo un resultado obliga a volver atrás



El proceso no es rígidamente lineal. Un hallazgo técnico a menudo exige regresar a fases previas:

- Un log revela una cuenta desconocida → Volver a Identificación.
- Se detecta un desfase horario → Volver a ajustar parámetros de Examen.
- Falla una herramienta técnica → Volver a Planificación para usar método alternativo.

Iterar NO es improvisar

Para que la iteración sea válida y auditable, la bitácora debe registrar rigurosamente:

- ✓ 1. Qué cambió: La nueva acción técnica a realizar.
- ✓ 2. Por qué: El hallazgo o error específico que justifica el cambio.
- ✓ 3. Autorización: Quién valida que el cambio sigue dentro del alcance.
- ✓ 4. Efecto: Cómo impacta en los productos verificables.

Gestión de contingencias (Ej. Hash discrepante o datos fuera de alcance)



1. Detener / Limitar: Detener la acción sobre esa fuente específica de inmediato.

2. Registrar: Anotar en la bitácora el estado exacto, la discrepancia o el hallazgo fuera de los límites.

3. Aislar y Preservar: Proteger la copia discrepante o la fuente sensible sin alterarla mientras se decide.

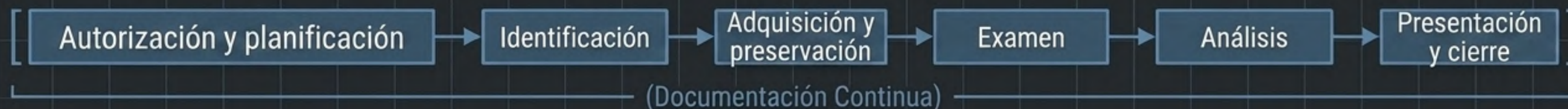
4. Comunicar: Informar a quien tiene la autoridad (supervisor/cliente) para que decida el curso de acción.

 **5. Continuar lo autorizado:** Continuar exclusivamente con otras fuentes o copias cuya integridad haya sido verificada y que permanezcan dentro del alcance autorizado.



Qué NO hacer: Abrir el original para "ver qué pasa", ignorar la discrepancia entre los valores hash, o continuar la revisión en secreto.

Mapa Compacto del Proceso Forense



Lista de comprobación para auditar un proceso:

- ✓ Acciones alineadas con el objetivo y la autorización.
- ✓ Entradas correctas y productos verificables en cada fase.
- ✓ Responsables y autorizaciones documentados.
- ✓ Original protegido y copias de trabajo verificadas.
- ✓ Hash, cadena de custodia y bitácora aplicados según su función.
- ✓ Examen claramente diferenciado del análisis.
- ✓ Datos faltantes, limitaciones e iteraciones declarados.